

Sensitive Data Governance

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 26: Compliance Frameworks and Standards

1. Why AI Requires a Different Mental Model for Data Governance

Traditional data governance treats data as records: files, database rows, documents. You classify the record, control who can access it, encrypt it at rest and in transit, and retain or delete it according to a schedule. AI systems break this model in three ways that require fundamentally different governance thinking.

First, AI systems encode data in a form that is not immediately recognizable as data. A language model trained on confidential internal communications does not store those communications as text — it distributes their patterns across billions of numerical parameters (weights). The data is there, but it looks like mathematics. Traditional access controls that protect a file do not protect the information once it is encoded in model weights.

Second, AI systems create new data from existing data. Inference logs — the record of what users asked and what the model answered — are new sensitive data assets that do not exist in traditional systems and require their own governance regime.

Third, AI systems amplify the consequences of data governance failures. A single poorly governed training dataset can produce a model that discriminates, leaks private information, or reproduces proprietary content at inference time — at scale, to millions of users, before the failure is detected. Sensitive data governance for AI is not an extension of traditional data governance; it is a different discipline applied to the same underlying assets.

Mental model shift: In traditional data governance, data is governed where it lives (files, databases). In AI governance, data must also be governed where it goes (training pipelines, model weights, inference logs, RAG knowledge bases) — and what it becomes (encoded model behavior).

2. Extending Data Classification to AI-Specific Asset Categories

Traditional classification schemes (public, internal, confidential, restricted) must be extended to cover four AI-specific asset categories. Exam scenarios that describe a data governance failure will often hinge on which of these categories was misclassified or ungoverned:

AI Data Asset Category	Sensitivity Level	Governance Requirement
Training datasets	Inherits highest classification of any included record	Govern the dataset at the most sensitive level present; document data lineage; apply retention schedule
Model weights	Confidential minimum if trained on confidential data; restricted if trained on restricted data	Classify and protect as data assets; access controls and encryption equivalent to source data

Inference inputs (user queries)	Transactional sensitive data; may contain personal, confidential, or privileged content	Classify per content; apply data minimization; govern retention of inference logs
Inference logs	Audit-critical; may contain personal data under GDPR, CCPA, HIPAA	Access controls; retention schedule; data subject rights obligations if personal data present

The key classification insight for model weights: a model trained on confidential internal data encodes that data in its parameters. The model file should be classified and protected at the same level as the data that produced it. Storing model weights in a publicly accessible storage bucket when the training data was confidential is a data governance failure equivalent to publishing the training data itself.

3. Real-World Incident: Samsung ChatGPT Leak and Training Data Exposure

Samsung Semiconductor Proprietary Data Leak via ChatGPT (2023): Three separate Samsung engineers transmitted proprietary semiconductor manufacturing source code and internal meeting minutes to ChatGPT within weeks of each other. The engineers were not malicious; they were using a tool that felt like a search engine for a task that felt like research. What they did not understand was that OpenAI's terms of service at the time permitted using user inputs for model improvement — meaning Samsung's proprietary chip fabrication data may have been encoded into OpenAI's models. Samsung had no data classification training specific to external AI service interactions, no DLP rules detecting proprietary code transmission to AI API endpoints, and no technical controls preventing the action. Samsung's response — banning generative AI tools on corporate devices — was reactive. The governance failure was structural: no one had extended the company's data classification scheme to ask 'what happens when this data enters an external AI training pipeline?'

The Samsung incident is the canonical example for exam scenarios testing sensitive data governance in AI context. Three governance controls would have prevented it: data classification training specifically addressing AI service interactions; DLP rules detecting transmission of confidential-classified data to external AI API endpoints; and a procurement review process requiring assessment of AI vendors' data handling practices before employee use is permitted.

4. NIST CSF 2.0 Applied to AI Data Governance

Sensitive data governance for AI maps to multiple NIST CSF 2.0 functions — it is not a single-function concern. Understanding this mapping helps practitioners identify which CSF implementation gaps create AI data governance exposure:

NIST CSF 2.0 Function / Category	AI Data Governance Application
ID.AM — Asset Management	AI training datasets and model weights must be inventoried as data assets alongside traditional data assets
PR.DS — Data Security	Training datasets at rest (AES-256, CMEK), model weights (same controls as source data), inference logs in transit (TLS 1.3+)

GV.RM — Risk Management	Training data risk (bias, leakage, membership inference) must be factored into AI system risk assessment
DE.AE — Adverse Event Analysis	AI-specific events: model inversion, membership inference, training data extraction, RAG unauthorized disclosure
PR.IP — Information Protection	Security controls on training pipelines, model storage, and inference infrastructure

Organizations with mature CSF 2.0 implementations often discover that their ID.AM (asset inventory) does not include training datasets or model weights, and their PR.DS (data security) controls have not been extended to cover AI pipeline components. These are the most common gaps in AI data governance programs.

5. Red Team View: Membership Inference and Training Data Extraction

Attackers with access to a fine-tuned model — including via public API — can probe for sensitive training data through two technically distinct but related attacks:

- Membership inference attacks: determine whether a specific record was included in the training dataset by observing the model's confidence differential. Models assign higher confidence (lower perplexity) to training examples than to unseen data. An attacker who can compare model confidence scores on candidate records versus control records can identify which records were in the training set — enabling targeted inference about whether specific individuals' data was used.
- Training data extraction attacks: use adversarial prompting to cause the model to reproduce verbatim content from its training data. The Carlini et al. research (2021, published; 2023, extended) demonstrated that large language models reproduce memorized training content — including names, contact details, source code, and proprietary text — under specific prompting conditions that exploit memorization of frequently occurring or high-distinctiveness training records.

Defenders mitigate these attack classes through three technical controls: differential privacy during training (adding calibrated noise to gradient updates, limiting the influence of any individual training record on model parameters), data minimization (not including sensitive data in training that is not necessary for the model's function), and output filtering to detect and block responses that appear to reproduce training data verbatim. The first is the most powerful — differential privacy provides formal mathematical guarantees about the maximum information leakage from any individual training record.

6. GDPR Obligations That Conflict with Standard AI Training Practices

GDPR creates specific obligations that directly conflict with how AI models are typically trained and deployed. These conflicts are exam-relevant because they test understanding of regulatory requirements that have no obvious technical analog in traditional data security:

- Right to erasure (Article 17): requires deletion of personal data upon request. If personal data is included in a model's training corpus, 'deleting' it from the model requires machine unlearning — technically non-trivial, computationally expensive, and not yet mature for large models. The practical approach is data minimization at training time: if personal data is not in the training set, erasure requests cannot conflict with the model.

- Right not to be subject to solely automated decisions (Article 22): individuals subject to solely automated decisions with legal or similarly significant effects must be given a meaningful explanation and the right to human review. AI models that produce decisions without human intervention trigger this right — and 'meaningful explanation' is technically difficult for models where predictions emerge from distributed weight representations.
- Data minimization (Article 5): only personal data necessary for the specified purpose may be processed. Training data curation for necessity is rarely standard practice — training sets are typically assembled for maximum coverage, not minimum personal data footprint.
- Legal basis: AI systems processing personal data of EU residents require a documented legal basis (consent, legitimate interest, contract performance) for each processing activity, including training, inference, and logging.

The exam will not test GDPR article numbers by rote, but will test whether candidates can identify which GDPR obligation creates a conflict with a described AI practice and what the compliant alternative is.

7. CCPA and the 'Sale or Sharing' Risk for AI Training

The California Consumer Privacy Act (CCPA), strengthened by CPRA effective January 2023, creates specific obligations relevant to AI training data:

- Right to know: California residents can request disclosure of what personal data has been collected and how it has been used — including in AI training.
- Right to delete: California residents can request deletion of their personal data, including from training datasets (with exceptions for certain legitimate uses).
- Right to opt out of sale or sharing: this is particularly relevant for AI training. If an organization uses personal data to train a model and makes that model available to third parties — even without direct monetary compensation — this may constitute 'sharing' of personal data under CCPA. The 'sharing' concept captures data flows that benefit the receiving party through AI capability improvement, not just traditional commercial data sale.
- Right to correct: California residents can request correction of inaccurate personal data — challenging when the data is encoded in model weights.

Privacy-by-design for AI training under CCPA means building the technical infrastructure to honor opt-outs and deletion requests across the AI system lifecycle before those requests arrive — not scrambling to comply reactively. The deletion request is the hardest: organizations need a documented process for handling deletion requests that may touch training data embedded in a deployed model.

8. Sensitive Data in RAG Architectures — A Distinct Governance Challenge

Retrieval-augmented generation (RAG) architectures — where an AI model retrieves documents from a knowledge base at inference time to augment its responses — create a sensitive data governance challenge that traditional access controls do not automatically address.

The problem: in a traditional document management system, access controls determine which users can retrieve which documents. In a RAG architecture, the AI model retrieves documents based on semantic similarity to the user's query — and if access controls are not synchronized between the knowledge base

and the AI system's retrieval layer, a user may receive document content in the AI's response that they have no authorization to see. The AI becomes an unintended data access pathway.

- **Vulnerable pattern:** employee queries the internal AI assistant about quarterly results. The RAG system retrieves restricted board-level financial documents because they are semantically relevant to the query. The employee never had access to those documents, but the AI system includes their content in its response.
- **Required controls:** document-level access control synchronized with the AI system's user identity context (the retrieval layer must enforce the same permissions as the document management system); output filtering to detect and block responses that include content the querying user is not authorized to see; comprehensive logging of all retrieved documents for audit purposes.

RAG governance principle: A RAG system must enforce document-level access controls at retrieval time — not just at document storage time. The AI system is an access pathway; it must apply the same permissions as the underlying document system for every query.

9. Synthetic Data as a Privacy-Preserving Governance Tool

Synthetic data generation has matured significantly as an approach to reducing the sensitive data footprint of AI training pipelines. Rather than training on real personal data, organizations generate synthetic datasets that preserve the statistical properties of real data — enabling realistic model training without exposure of actual personal records.

Leading platforms in this space include Gretel.ai, Mostly AI, Hazy, and YData. These tools use techniques including variational autoencoders (VAEs), generative adversarial networks (GANs), and diffusion models to generate tabular and text synthetic data. The privacy claim is not absolute — re-identification attacks against synthetic datasets are possible, particularly for small datasets or outlier records — but synthetic data substantially reduces the sensitive data footprint and can satisfy regulatory requirements in contexts where using real personal data would require explicit consent or create unacceptable privacy risk.

For practitioners, synthetic data is a governance tool with specific use cases: replacing personal data in development and testing environments, augmenting small real datasets while limiting personal data exposure, and satisfying data minimization requirements for model training where the model's function does not require real personal data. Its privacy guarantees should be documented and validated — 'we used synthetic data' is not a compliance statement without evidence of the generation method and privacy testing performed.

10. Data Retention and Lifecycle for AI-Specific Asset Categories

AI data lifecycle governance requires explicit policies for asset categories that most enterprise data retention schedules do not address:

AI Data Asset	Retention Consideration	Governance Requirement
Training datasets	How long retained; access controls during retention	Documented retention schedule; deletion certificates; data subject deletion rights

		honored
Model weights (deployed)	Retained while model is in production	Access controls equivalent to source data; inventory entry; incident response plan
Model weights (deprecated)	Risk of reactivation creating compliance exposure	Formal decommissioning process; weight deletion or secure archiving with access controls
Inference logs	May contain personal data; audit-critical	Defined retention period; access controls; data subject rights process for personal data in logs
Model versions	Older models trained on since-deleted data	Assess whether deprecated model weights create ongoing compliance exposure; decommission if so

The model decommissioning gap is frequently missed: an organization deletes personal data from its training database in response to a GDPR erasure request, but the model trained on that data — now deprecated — remains accessible. If the deprecated model's weights are not also secured or deleted, the erasure is incomplete. ISO/IEC 42001 Annex A clause 7 (data for AI systems) and clause 8 (operation) both address data lifecycle management across the AI system lifecycle.

11. Technical Controls for AI Data Security

Sensitive data governance for AI is Section 6's data security principles applied to a new class of data assets. The controls are not new — the application is:

- Encryption at rest: training datasets and model weights should be encrypted using AES-256 with customer-managed keys (AWS KMS, Azure Key Vault, HashiCorp Vault). Customer-managed keys ensure the organization retains control of the cryptographic keys, enabling key rotation and revocation.
- Encryption in transit: all data moving between training pipeline components should use TLS 1.3 or above. Data in transit between inference infrastructure and client applications requires equivalent protection.
- Role-based access control (RBAC): access to training datasets and model weights should be role-based, logged, and subject to periodic access review. Data scientists who trained a model two years ago and have since moved to different work should not retain access to the training dataset.
- Audit logging: all access to training datasets and model weights should be logged for post-incident investigation and compliance reporting.
- DLP for AI pipelines: DLP controls should flag transmission of training dataset content to external services — catching the Samsung-type failure before the data leaves.

12. Exam Angle: Data Governance Failure Mode Recognition

SecAI+ exam scenarios on sensitive data governance test recognition of specific failure modes and their corresponding controls. The exam presents a scenario and asks either what went wrong or what control would have prevented it:

Failure Mode	What Went Wrong	Correct Control
Personal data in training — no minimization	Violates GDPR data minimization (Article 5); creates membership inference risk	Data minimization before training; synthetic data substitution
Deletion request can't be honored — data in model weights	GDPR Article 17 violation; model retraining or machine unlearning required	Data minimization at training time prevents the conflict
RAG system returns unauthorized document content	Retrieval layer doesn't enforce document-level access controls	Synchronized access controls at retrieval layer; output filtering
Deprecated model trained on deleted data still accessible	Erasure is incomplete; model weights retain encoded deleted data	Formal decommissioning process deleting or securing deprecated weights
Inference logs retained indefinitely containing personal data	Retention policy violation; GDPR/CCPA data subject rights exposure	Defined inference log retention schedule; access controls
Model weights stored in public bucket — source data was confidential	Model classified below source data sensitivity level	Classify model weights at same level as source training data

Key Terms Glossary

Term	Definition
Training dataset	The collection of data used to train an AI model; must be governed at the most sensitive classification level of any included record.
Model weights	The numerical parameters that encode a trained model's learned behavior; should be classified and protected at the same sensitivity level as the source training data.
Inference logs	Records of user inputs to and model outputs from an AI system during operation; may contain personal data subject to GDPR, CCPA, or HIPAA depending on context.
Membership inference attack	An attack that determines whether a specific record was included in a model's training dataset by observing confidence differentials in model predictions.
Training data extraction attack	An adversarial prompting technique that causes a model to reproduce verbatim content from its training data, exposing memorized sensitive information.
Differential privacy	A mathematical framework for limiting the influence of any individual record on a model's trained parameters, providing formal guarantees against membership inference.
RAG (Retrieval-Augmented Generation)	An AI architecture where a model retrieves documents from a knowledge base at inference time; requires document-level access controls synchronized with the retrieval layer.
GDPR Article 17 (Right to Erasure)	The 'right to be forgotten' — requires deletion of personal data

	upon request; creates compliance complexity when personal data is encoded in model weights.
GDPR Article 22	The right not to be subject to solely automated decisions with legal or similarly significant effects; requires human oversight and meaningful explanation for covered AI decisions.
Data minimization	The principle (codified in GDPR Article 5 and AI responsible use frameworks) that only personal data necessary for the specified purpose should be collected and processed.
Synthetic data	Artificially generated data that preserves statistical properties of real data without containing actual personal records; used to reduce sensitive data footprint in AI training pipelines.
Machine unlearning	The technical process of removing the influence of specific training records from a deployed model; computationally expensive and not yet mature for large models.

Quick Revision Checklist

- AI data governance requires a different mental model: data must be governed where it goes (training pipelines, model weights, inference logs, RAG knowledge bases), not just where it lives.
- Extend data classification to four AI-specific asset categories: training datasets, model weights, inference inputs, and inference logs.
- Model weights must be classified and protected at the same level as the source training data that produced them.
- Samsung (2023): three independent data leaks to ChatGPT — no DLP, no data classification training, no AI-specific procurement review.
- Membership inference attacks identify whether records were in training data; training data extraction attacks recover verbatim training content.
- Differential privacy provides formal mathematical guarantees against membership inference by limiting individual record influence on model parameters.
- GDPR Article 17 (right to erasure) conflicts with AI model deployment when personal data is in training sets — data minimization at training time prevents the conflict.
- RAG architectures require document-level access controls synchronized at the retrieval layer — the AI is an access pathway and must enforce permissions.
- Synthetic data reduces sensitive data footprint; privacy guarantees depend on generation method and must be documented and tested.
- Deprecated model weights trained on since-deleted data create ongoing compliance exposure — formal decommissioning processes must address weight deletion.
- NIST CSF 2.0 ID.AM must include training datasets and model weights; PR.DS controls must extend to AI pipeline components.

10 Exam-Based MCQs — Sensitive Data Governance

Test yourself after reading. These questions mirror the scenario-heavy, distractor-rich style of the CompTIA SecAI+ exam. Read every explanation including for questions you answered correctly.

Q1. Scenario: A healthcare AI company trained a diagnostic support model on a dataset of 500,000 anonymized-but-re-identifiable patient records from a partner hospital network. Eighteen months after model deployment, the company receives a GDPR Article 17 erasure request from a patient whose records were included in the training data. A healthcare AI company trains a diagnostic support model using patient records. After deployment, the model's vendor receives a GDPR Article 17 erasure request from a patient whose records were included in the training dataset. What is the most significant technical challenge in honoring this request?

- A) The patient's records must be deleted from the production database, which requires downtime
- B) Deleting the patient's data from the deployed model requires machine unlearning or full model retraining — technically complex and computationally expensive, with no mature standardized process for large models
- C) GDPR Article 17 does not apply to medical data processed for diagnostic purposes
- D) The erasure request must be denied because honoring it would degrade model performance

Answer: B **Explanation:** B is correct: the fundamental challenge is that personal data encoded in model weights is not a discrete record that can be deleted with a database command. Removing one person's data from a trained model requires machine unlearning (selectively modifying weights to remove learned patterns from specific records) or full retraining on a dataset that excludes the individual's records. Neither is technically trivial at scale, and machine unlearning is not yet mature for large models. The preventive solution is data minimization at training time — if the patient's data was never in the training set, no erasure conflict exists. A is wrong: the production database deletion is straightforward; the model weights are the hard part. C is wrong: GDPR Article 17 applies broadly to personal data; medical diagnostic processing does not categorically exempt erasure rights. D is wrong: a model cannot validly deny a GDPR right because honoring it is inconvenient.

Q2. An organization deploys an internal AI assistant using a RAG architecture. The knowledge base contains both general company policy documents (accessible to all employees) and restricted board-level financial documents (accessible only to senior executives). An analyst queries the AI assistant about quarterly performance and receives a response that includes specific figures from a restricted board document. Which control failure caused this?

- A) The AI assistant did not apply output filtering to remove financial data from responses
- B) The RAG knowledge base lacked encryption at rest, allowing unauthorized document access
- C) The retrieval layer did not enforce document-level access controls synchronized with the user's identity context, allowing retrieval of restricted documents based on semantic relevance alone
- D) The inference logs were not reviewed for unauthorized data disclosure

Answer: C **Explanation:** C is correct: in a RAG architecture, the retrieval layer retrieves documents based on semantic similarity to the query — not based on user authorization. If the retrieval layer does not enforce document-level access controls synchronized with the querying user's identity (i.e., the same permissions that would apply if the user tried to access the document directly), semantically relevant restricted documents will be retrieved and included in the AI's response. The analyst had no authorization to see the board documents, but the AI's retrieval step had no mechanism to enforce that restriction. A is wrong: output filtering is a mitigating detective control, not the root cause of the failure — the root is retrieval without access control enforcement. B is wrong: encryption at rest protects data from external

attack; it does not address authorized-path access control failures within the RAG system. D is wrong: log review is a detective control that would identify the disclosure after the fact, not the control failure that caused it.

Q3. A data scientist at a financial services firm fine-tunes a language model on internal client communications to build a client inquiry response assistant. The model is stored in the firm's shared object storage with read access granted to all data engineering team members. The original client communications are classified as Restricted. What data governance failure has occurred?

- A) The model was fine-tuned without obtaining client consent, violating the terms of service for the underlying foundation model
- B) The model weights should be classified as Restricted and protected with equivalent access controls to the source training data, but they are stored with broad access
- C) The model should have been trained using synthetic data rather than actual client communications
- D) The inference logs from the client inquiry assistant have not been reviewed for data quality

Answer: B **Explanation:** B is correct: model weights trained on Restricted data encode that data in their parameters and must be classified and protected at the same sensitivity level. Storing a model trained on Restricted client communications in shared object storage accessible to all data engineering team members is equivalent, from a data governance standpoint, to storing the client communications themselves in that location. The control failure is misclassification and under-protection of model weights. A is wrong: the scenario does not indicate a foundation model terms of service issue; this is an internal fine-tuning governance question. C is wrong: using real client communications may be appropriate for the business use case; the failure is in protecting the resulting model, not in the training approach per se. D is wrong: inference log review is an ongoing monitoring activity; the data governance failure identified in the scenario is a classification and access control failure for the model weights.

Q4. The Carlini et al. research on training data extraction from large language models demonstrated which security risk for organizations deploying or fine-tuning LLMs on sensitive data?

- A) LLMs are vulnerable to prompt injection attacks that allow attackers to execute arbitrary code on the inference server
- B) LLMs will reproduce verbatim training content — including names, contact information, source code, and proprietary text — under specific adversarial prompting conditions
- C) LLM inference is susceptible to side-channel timing attacks that reveal model architecture details
- D) LLM outputs are systematically biased toward content that appeared most frequently in the training data, regardless of factual accuracy

Answer: B **Explanation:** B is correct: the Carlini et al. research (2021, 2023) demonstrated that large language models memorize and reproduce verbatim content from training data under specific prompting conditions — including personally identifiable information, contact details, source code, and proprietary text. This is the training data extraction risk that organizations must mitigate through differential privacy, data minimization, and output filtering. A is wrong: prompt injection is a separate attack class (covered in the OWASP LLM Top 10); Carlini's research specifically addressed training data memorization and

extraction. C is wrong: Carlini's research is about semantic content extraction through prompting, not hardware-level side-channel attacks. D is wrong: while frequency bias exists and is a separate concern, Carlini's research focused on verbatim memorization, not frequency-based output distortion.

Q5. Under CCPA as strengthened by CPRA, which scenario involving an organization's AI training data MOST likely constitutes prohibited 'sale or sharing' of personal data, requiring opt-out rights for California residents?

- A) An organization trains a model on internal employee data and uses the model only for internal HR analytics
- B) An organization trains a model on customer personal data and makes the resulting model available to a business partner for use in the partner's customer-facing applications, even without direct monetary compensation
- C) An organization processes customer order data through an AI recommendation model to generate product suggestions displayed to the same customers
- D) An organization uses synthetic data generated from anonymized customer records to train a fraud detection model

Answer: B **Explanation:** B is correct: CCPA/CPRA's 'sharing' concept captures data flows where personal data (or capability derived from it) benefits a third party — not just traditional commercial data sale. Making a model trained on customer personal data available to a business partner, even without direct compensation, enables the partner to benefit from patterns learned from customers' personal data. This likely constitutes 'sharing' requiring California residents' opt-out rights. A is wrong: internal use of employee data for internal analytics does not involve sharing with a third party; CCPA applies to consumer data, and employees in an employer-employee context are covered by different CCPA provisions. C is wrong: using customer data to power recommendations for those same customers is first-party processing for a disclosed purpose, not 'sharing' with a third party. D is wrong: synthetic data generated from anonymized records is not itself personal data; using it for training does not constitute sharing of personal data.

Q6. An AI team wants to train a model on customer support conversation logs to improve response quality. The logs contain customers' names, account numbers, and descriptions of their issues. The data privacy team recommends differential privacy during training. What specific protection does differential privacy provide in this context?

- A) It encrypts the training data so that data scientists cannot read individual customer records
- B) It generates synthetic versions of all training records before model training begins
- C) It adds calibrated noise to gradient updates during training, limiting the influence of any individual customer's records on the model's parameters and providing mathematical bounds on information leakage
- D) It applies role-based access controls to the training pipeline so only authorized data scientists can access the training data

Answer: C **Explanation:** C is correct: differential privacy in model training works by adding carefully calibrated noise to the gradient updates during training — the mechanism by which individual training

records influence model parameters. This limits (with mathematical guarantees) the maximum amount of information any individual record can contribute to the trained model, making membership inference attacks and training data extraction attacks substantially harder. The formal guarantee is that the probability of any output from the trained model changes by at most a bounded factor (epsilon) whether or not any individual record is included. A is wrong: differential privacy is applied during training (to gradient updates), not to data at rest — encryption is a separate control. B is wrong: synthetic data generation is a separate privacy-preserving technique, not differential privacy. D is wrong: RBAC is an access control mechanism, not a privacy protection mechanism for model training.

Q7. An organization's AI governance program classifies its training datasets in the asset inventory but does not include model weights as classified data assets. A legacy model trained on Restricted customer data two years ago is stored in a development team's shared drive, accessible to junior developers. What governance framework gap does this illustrate?

- A) Failure to extend the NIST CSF 2.0 ID.AM (Asset Management) function to include model weights as classified data assets requiring protection equivalent to their source training data
- B) Failure to apply NIST CSF 2.0 PR.PS (Platform Security) controls to the inference infrastructure
- C) Failure to implement differential privacy during the model's original training
- D) Failure to conduct an AI system impact assessment before deploying the model

Answer: A **Explanation:** A is correct: NIST CSF 2.0 ID.AM requires inventorying and classifying assets to enable appropriate protection. Model weights are data assets that must be included in the asset inventory and classified at the same level as the data that produced them. The governance gap is the failure to extend ID.AM to recognize model weights as classified assets — a gap that allows Restricted customer data (encoded in model parameters) to be stored with the protection level of unclassified development assets. B is wrong: PR.PS covers platform security controls for the systems running the model; the gap here is in asset classification, not platform security. C is wrong: differential privacy is a training-time control; the failure described is a post-training storage and classification gap. D is wrong: impact assessment is relevant to deployment governance; the gap described is in ongoing asset management of the model weights.

Q8. An organization decommissions an AI model after three years of production use. The model was fine-tuned on customer data, some of which has since been deleted from production databases in response to GDPR deletion requests. The model weights are archived in long-term storage 'just in case.' What governance risk does this create?

- A) The archived model weights may be used to re-identify deleted customer data, making the GDPR deletion incomplete for those customers whose data is encoded in the weights
- B) The archived model weights may degrade over time, creating a reliability risk if the model is reactivated
- C) Archiving model weights violates ISO/IEC 42001 Annex A clause 8, which prohibits retention of deprecated AI systems
- D) The archived model creates a vendor support risk because the underlying framework may become unsupported

Answer: A **Explanation:** A is correct: deleted data is only truly deleted if all copies — including derived

representations — are also deleted or made inaccessible. Model weights that encode patterns learned from since-deleted customer data may allow those customers' data to be extracted or inferred (through membership inference or training data extraction). The GDPR deletion is incomplete as long as model weights encoding that data remain accessible. Proper AI decommissioning includes assessing whether deprecated model weights create ongoing data subject rights exposure and deleting or securely archiving them with appropriate access controls. B is wrong: weight degradation is not a risk — weights are static numerical parameters that do not decay. C is wrong: ISO/IEC 42001 does not prohibit retention of deprecated models; it requires lifecycle management, including appropriate decommissioning processes. D is wrong: vendor support for frameworks is a technical risk, not the primary governance risk described.

Q9. A company uses a synthetic data platform to generate training data for a fraud detection model, replacing real customer transaction records. The data privacy team declares this approach 'GDPR-compliant by design.' What limitation must the practitioners validate before accepting this claim?

- A) Synthetic data may not be statistically representative enough to train an effective fraud detection model
- B) Re-identification attacks against synthetic datasets are possible, particularly for small datasets or outlier records, so privacy guarantees depend on the generation method and must be tested and documented — 'we used synthetic data' is not itself a compliance statement
- C) GDPR does not recognize synthetic data as a valid basis for processing personal information
- D) The fraud detection model must also be trained on real data to satisfy the accuracy requirements of PSD2 regulations

Answer: B **Explanation:** B is correct: synthetic data substantially reduces the sensitive data footprint and can satisfy regulatory requirements in many contexts, but its privacy guarantees are not absolute. Re-identification attacks against synthetic datasets are documented, particularly where the dataset is small, contains outlier records, or the generation method preserves statistical relationships too faithfully. The compliance claim requires: documentation of the generation method (VAE, GAN, diffusion model), privacy testing (re-identification attack resistance), and formal validation that the method provides sufficient privacy protection for the sensitivity of the source data. A is wrong: statistical representativeness is a model quality concern, not the governance validation being asked about. C is wrong: GDPR does not prohibit synthetic data; it governs the processing of personal data, and properly anonymized synthetic data may fall outside GDPR's scope entirely. D is wrong: PSD2 accuracy requirements do not specifically mandate real transaction data for training; this is not the relevant governance concern.

Q10. A security analyst is reviewing an organization's AI governance program against NIST CSF 2.0 and finds that the asset inventory (ID.AM) lists training datasets but not model weights, and that the data security controls (PR.DS) applied to training pipelines have not been assessed. Which governance gap BEST describes this finding?

- A) The organization has not conducted an AI system impact assessment as required by ISO/IEC 42001 Annex A.6.1

- B) The organization's NIST CSF 2.0 implementation has not been extended to cover AI-specific data assets (model weights) and AI pipeline components (training infrastructure), creating unaddressed data security exposure
- C) The organization lacks a GDPR-compliant data processing agreement with its cloud provider for training pipeline operations
- D) The organization's human oversight controls are insufficient for AI-assisted decisions

Answer: B **Explanation:** B is correct: the finding describes a classic AI data governance gap in an otherwise mature CSF 2.0 program — the ID.AM asset inventory covers traditional data assets but has not been extended to include model weights, and PR.DS data security controls have not been assessed for AI pipeline components (training infrastructure, model storage, inference logging). This is the most common gap practitioners find when extending CSF 2.0 to AI governance: the framework is in place, but the AI-specific asset categories and infrastructure components have not been incorporated. A is wrong: the finding is about asset inventory and data security controls — impact assessment (A.6.1) is a deployment governance requirement, not what the finding describes. C is wrong: the finding does not describe a data processing agreement gap; it describes an asset classification and control gap. D is wrong: human oversight is a deployment governance control — the finding is about asset management and data security, not decision oversight.